

1. Объект тестирования

DemoQA Book Store API

Тестирование проводилось для REST API учебного сервиса DemoQA Book Store.

Проверены два блока API:

- **Account** — создание пользователя, получение токена, проверка авторизации, получение и удаление пользователя;
- **BookStore** — получение книг, добавление и удаление книг из коллекции пользователя, получение отдельной книги и замена книги.

Всего проанализировано и протестировано **11 endpoint**.

2. Использованные инструменты

- **Swagger** — анализ доступных endpoint, параметров, моделей запросов и ответов;
- **Postman** — отправка HTTP-запросов и работа с Environment variables и Bearer token;
- **YouTrack** — оформление найденных дефектов;
- **Google Sheets / Excel** — ведение API-чек-листа и фиксация результатов тестирования.

3. Проведённые проверки

В рамках тестирования проверялись:

- позитивные и основные негативные сценарии;
- создание и удаление пользователя;
- получение и проверка Bearer token;
- доступ к защищённым endpoint с валидным, отсутствующим и невалидным token;
- добавление, получение, удаление и замена книг;
- работа с существующими и несуществующими **userId** и **ISBN**;
- отсутствие обязательных параметров и полей request body;
- повторное выполнение операций;
- HTTP-коды ответов;
- структура и типы данных response;
- соответствие фактических ответов схемам Swagger;
- фактическое изменение состояния коллекции через контрольные GET-запросы.

4. Результаты тестирования

Всего выполнено **66** проверок:

Результат	Количество	Доля
Passed	50	75,8%
Failed	16	24,2%
Blocked	0	0%
Всего	66	100%

По блокам:

Блок	Passed	Failed	Всего
Account	20	8	28
BookStore	30	8	38

По результатам тестирования в YouTrack оформлено **8 баг-репортов**.

Количество Failed-проверок больше количества баг-репортов, поскольку одно и то же несоответствие API-контракту может воспроизводиться на нескольких endpoint.

5. Основные обнаруженные проблемы

Валидация входных данных

- POST /Account/v1/User позволяет создать пользователя с **userName** типа **number**, несмотря на тип **string** в Swagger.
- Передача **password** типа **number** приводит к 504 Gateway Time-out.
- Отсутствие **userId** или **collectionOfsbns** в POST /BookStore/v1/Books приводит к 504 Gateway Time-out вместо корректной обработки ошибочного запроса.
- Отсутствие обязательного **ISBN** в GET /BookStore/v1/Book также приводит к 504 Gateway Time-out.

Соответствие Swagger

- Поле **code** модели **MessageModal** фактически возвращается как **string**, хотя в Swagger определено как **number**.
- Обнаружены дополнительные расхождения между фактическими ответами API и описанием Swagger, включая названия/типы отдельных полей и поведение некоторых DELETE-запросов.

Корректность response

- При замене книги на ISBN, уже находящийся в коллекции, PUT /BookStore/v1/Books/{ISBN} возвращает в response две одинаковые книги, тогда как последующий GET показывает только одну книгу в фактической коллекции.

Безопасность

- JWT, получаемый через POST /Account/v1/GenerateToken, содержит пароль пользователя в payload. Payload JWT может быть декодирован без секретного ключа, поэтому пароль не должен передаваться в нём.

6. Итог

Основные позитивные сценарии Account и BookStore API работают: пользователь может быть создан, авторизован, получить данные аккаунта, а книги можно получать и изменять в пользовательской коллекции.

При этом в API обнаружены проблемы с **валидацией входных данных, обработкой ошибок, соответствием Swagger фактической реализации, формированием response и безопасностью JWT**.

Наиболее заметная проблема обработки некорректных запросов — несколько сценариев приводят к длительному ожиданию и 504 Gateway Time-out вместо контролируемого API-ответа об ошибке.

Все выполненные проверки зафиксированы в API-чек-листе, а основные обнаруженные дефекты оформлены в YouTrack.